

Informe sobre CISA KEV y Métricas Nacionales de Ciberseguridad (Enfoque España – Perspectiva Global)

1. Resumen ejecutivo

Desde 2024, el catálogo de **Known Exploited Vulnerabilities (KEV)** de CISA se ha consolidado como el “metronomo” mundial de qué vulnerabilidades pasan del mundo de lo **potencial** a lo **realmente explotado**. El ritmo no baja: en 2023 se añadieron 187 vulnerabilidades, en 2024 unas 185–186, y en 2025 el crecimiento vuelve a acelerarse hasta 245 nuevas entradas, superando las 1.4k vulnerabilidades acumuladas en el catálogo.¹²³

-
- 2 <https://cyble.com/blog/cisa-known-exploited-vulnerabilities-catalog-update/>
 - 2 <https://thecyberexpress.com/cisa-known-exploited-vulnerabilities-kev-2025/>
 - 2 <https://socradar.io/cisa-kev-2024-review-trends-from-the-past-year/>
 - 2 <https://breached.company/enisa-threat-landscape-briefing-2024-2025-analysis/>
 - 2 https://www.redseguridad.com/actualidad/ciberseguridad/enisa-lanza-una-base-de-datos-europea-de-vulnerabilidades-para-reforzar-la-ciberseguridad-en-la-ue_20250519.html
 - 2 <https://thecyberexpress.com/cisas-2024-kev-catalog-update/>
 - 2 <https://socradar.io/cisa-kev-2024-review-trends-from-the-past-year/>
 - 2 <https://cyble.com/blog/cisa-known-exploited-vulnerabilities-catalog-update/>
 - 2 <https://thecyberexpress.com/cisa-known-exploited-vulnerabilities-kev-2025/>
 - 2 <https://arxiv.org/html/2411.02618v1>
 - 2 <https://www.techrxiv.org/users/1014795/articles/1378267-prediction-meets-patch-queues-empirical-limits-of-epss-only-prioritization-using-cisa-kev-additions-in-2025>
 - 2 <https://www.cyentia.com/wp-content/uploads/2024/07/EPSS-Exploration-Of-Exploits.pdf>
 - 2 <https://arxiv.org/html/2411.02618v1>
 - 2 <https://www.aptori.com/blog/comparing-nist-lev-epss-and-kev-for-vulnerability-prioritization>
 - 2 <https://www.edgescan.com/wp-content/uploads/2024/03/2023-Vulnerability-Statistics-Report.pdf>
 - 2 <https://www.cyentia.com/wp-content/uploads/2024/07/EPSS-Exploration-Of-Exploits.pdf>
 - 2 <https://arxiv.org/html/2411.02618v1>
 - 2 <https://authlab.com/community/organization-patching-cisa-kev-vulnerabilities-3-5-times-faster-than-other-vulnerabilities/>
 - 2 https://netlas.io/blog/when_patches_fail/
 - 2 <https://www.bitsight.com/press-releases/bitsight-reveals-more-60-percent-known-exploited-vulnerabilities-remain-unmitigated>
 - 2 https://www.redseguridad.com/actualidad/ciberseguridad/enisa-lanza-una-base-de-datos-europea-de-vulnerabilidades-para-reforzar-la-ciberseguridad-en-la-ue_20250519.html
 - 2 <https://www.ccn-cert.cni.es/es/informes/informes-ccn-cert-publicos/7274-ccn-cert-ia-04-24-ciberamenazas-y-tendencias-edicion-2024/file.html>
 - 2 <https://media.defense.gov/2024/Nov/12/2003581596/-1/-1/0/CSA-2023-TOP-ROUTINELY-EXPLOITED-VULNERABILITIES.PDF>

En paralelo, estudios de grandes proveedores (Qualys, Rapid7, Mandiant, Bitsight, ENISA, CCN-CERT, etc.) muestran un patrón consistente:

- Apenas ~1% de las nuevas CVE son weaponizadas en el corto plazo, pero su impacto desproporcionado explica buena parte de los incidentes graves.⁴⁵⁶⁷
- Las KEV son mucho más prevalentes que las vulnerabilidades “normales” y, aun así, se parchean tarde y mal: mediana de 174 días frente a 621 días para vulnerabilidades no KEV.⁸
- La explotación se desplaza con decisión hacia dispositivos perimetrales, VPN, firewalls, file transfer y software de infraestructura (CI/CD, MDM, etc.), con una proporción elevada de zero-days en appliances de red.⁹¹⁰¹¹¹²

En Europa, ENISA incorpora **245 KEV añadidas** durante su último periodo de referencia y destaca que la explotación de vulnerabilidades es el segundo vector de intrusión más eficaz tras el phishing, en un contexto de 42.595 nuevas vulnerabilidades divulgadas (+27% interanual). La nueva **EU Vulnerability Database (EUVD)** se alimenta explícitamente del catálogo KEV de CISA, entre otras fuentes, como pieza de soberanía tecnológica y pilar de NIS2 y la futura Cyber Resilience Act.⁴⁵

En España, el **CCN-CERT** constata que:

-
- 2 <https://media.defense.gov/2023/Aug/03/2003273618/-1/-1/0/JOINT-CSA-2022-TOP-ROUTINELY-EXPLOITED-VULNERABILITIES.PDF>
 - 2 <https://www.ccn-cert.cni.es/es/informes/informes-ccn-cert-publicos/7274-ccn-cert-ia-04-24-ciberamenazas-y-tendencias-edicion-2024/file.html>
 - 2 https://securitydelta.nl/media/com_hsd/report/690/document/ENISA-Threat-Landscape-2024.pdf
 - 2 https://www.redseguridad.com/actualidad/ciberseguridad/enisa-lanza-una-base-de-datos-europea-de-vulnerabilidades-para-reforzar-la-ciberseguridad-en-la-ue_20250519.html
 - 2 <https://breached.company/enisa-threat-landscape-briefing-2024-2025-analysis/>
 - 2 <https://www.revenera.com/blog/software-composition-analysis/cisas-kev-catalog-focusing-on-what-matters/>
 - 2 <https://cyble.com/blog/cisa-known-exploited-vulnerabilities-catalog-update/>
 - 2 <https://thecyberexpress.com/cisa-known-exploited-vulnerabilities-kev-2025/>
 - 2 <https://socradar.io/cisa-kev-2024-review-trends-from-the-past-year/>
 - 2 <https://breached.company/enisa-threat-landscape-briefing-2024-2025-analysis/>
 - 2 <https://www.bitsight.com/press-releases/bitsight-reveals-more-60-percent-known-exploited-vulnerabilities-remain-unmitigated>

- Las vulnerabilidades más explotadas siguen siendo antiguas y muy extendidas (Office, WinRAR, etc.).¹⁴
- Los atacantes muestran una fuerte preferencia por el compromiso de dispositivos perimetrales vulnerables y cadenas de phishing + explotación de CVE conocidas.¹⁴
- España figura entre los países más atacados por grupos hacktivistas prorrusos, con DDoS y explotación de sistemas expuestos, lo que amplifica el riesgo asociado a KEV no parcheadas en Administración y operadores críticos.¹⁵¹⁴

Aunque no hay aún estadísticas públicas detalladas de “**porcentaje de organizaciones españolas con KEV abiertas**”, los datos globales de Bitsight (1,4 M de organizaciones analizadas) ofrecen una línea base razonable para diseñar métricas nacionales:

Indicador global (Bitsight, 2023)	Valor de referencia
Organizaciones con ≥ 1 KEV	35% de organizaciones analizadas ⁸
Organizaciones con ≥ 5 KEV	25% de las que tienen KEV ⁸
Mediana tiempo de remediación KEV	174 días (≈ 6 meses) ⁸
Mediana KEV críticas	137 días ($\approx 4,5$ meses) ⁸
Mediana tiempo no-KEV	621 días ($> 1,7$ años) ⁸
Plazos CISA incumplidos	$> 60\%$ de los casos ⁸

El mensaje subyacente es incómodo pero claro: **el catálogo KEV funciona como priorizador global**, pero los países (España entre ellos) todavía están lejos de cerrar estas brechas con la velocidad que el riesgo exige. Desde una óptica de política pública y de métricas nacionales, KEV ofrece un eje muy fértil para:

- Medir la exposición real de un país a vulnerabilidades explotadas.
- Evaluar la capacidad de respuesta (tiempos de parcheo, cumplimiento de SLAs).
- Comparar sectores, territorios y países en términos de resiliencia digital.

En las secciones siguientes se detalla el panorama KEV desde 2024, la posición europea y española, y se propone un **marco concreto de indicadores y métricas nacionales para España**, con referencias comparativas globales y, al final, un módulo de **preguntas y opciones de respuesta para encuestas**, con el tono ligero, irónico y constructivo que merece cualquier cuestionario que aspire a ser respondido sin bostezos.

2. Metodología y alcance

Fuentes utilizadas

- Documentación oficial de CISA (BOD 22-01, KEV, Top Routinely Exploited Vulnerabilities).16171819
- Estudios de proveedores de seguridad (Rapid7, Qualys, Mandiant, Bitsight, Edgescan, etc.).105111220948
- Informes de ENISA (Threat Landscape 2024 y briefing 2024-2025).2122237
- Informes nacionales de CCN-CERT e información operativa de INCIBE-CERT.2425261514
- Análisis académicos y técnicos sobre KEV, EPSS y priorización de vulnerabilidades (arXiv, TechRxiv, Cyentia).272829
- Artículos técnicos y resúmenes de CISA sobre vulnerabilidades más explotadas en 2023–2024.301819

Ventana temporal

- Tendencias clave desde 2023, con foco especial en datos 2024–2025, que es donde KEV se estabiliza primero y vuelve a acelerarse después.2317

3. Panorama global de las KEV desde 2024

3.1 Crecimiento y estabilización del catálogo KEV

Diversos análisis de terceros sobre el propio catálogo KEV dibujan una trayectoria clara:

Año	Nuevas KEV añadidas	Total aprox. al final de año	Comentario
2021 (lanzamiento)	~300 iniciales en pocos meses ¹	~300+	Fase de arranque, “backlog histórico”.
2022	~500 en primeros 6 meses ¹	~800	Expansión agresiva inicial.
2023	187 nuevas KEV ¹²³	~1.050	Crecimiento anual ≈21%.
2024	185–186 nuevas KEV; total ≈1.238–1.251 ³¹¹³	~1.250	Ritmo estable, ligera normalización.
2025	245 nuevas KEV; total 1.484 ²	1.484	Reaceleración (+20% catálogo en un año).

Aunque distintas fuentes dan cifras totales ligeramente diferentes (1.238 vs 1.251 vulnerabilidades), coinciden en el orden de magnitud y en la forma de la curva: **fuerte crecimiento inicial, meseta en 2023–2024 y nuevo salto en 2025**.⁶⁷⁸⁹

3.2 KEV frente al océano de CVEs

Varios informes permiten situar KEV en el contexto del “mar de CVEs”:

- Qualys estima que, entre enero y mediados de julio de 2024, se publicaron 22.254 CVEs, un 30% más que el mismo periodo del año anterior.⁵⁶⁴
- De esas nuevas CVE, 204 fueron weaponizadas en ese periodo: un 0,91% de las nuevas vulnerabilidades.⁶⁴⁵
- ENISA reporta 42.595 vulnerabilidades divulgadas en su último periodo (jul 2024–jun 2025, +27% anual), de las que 245 se convirtieron en KEV durante ese tiempo.⁷

Esto sugiere, con todas las cautelas, que:

- Solo una fracción muy pequeña (~1%) de las nuevas CVE acaba siendo explotada de forma suficientemente relevante como para entrar en KEV.
- Aun así, esa fracción explica una porción desproporcionada de incidentes graves, ransomware y campañas estatales.¹⁸¹⁹⁹¹⁰³⁰

3.3 Naturaleza de las vulnerabilidades KEV (2023–2025)

Las tendencias técnicas desde 2023 son claras:

1. Dispositivos perimetrales y appliances de red
Rapid7 constata que el 24% de las vulnerabilidades explotadas en su conjunto de datos son “network pivot vulnerabilities” (puertas de pivoteaje en el perímetro), mientras que en KEV $\approx 19\%$ de las entradas afectan a dispositivos de borde o pasarelas de seguridad.¹¹⁹
Mandiant muestra que en 2024 la mayor parte de los incidentes con exploit como vector inicial se debieron a vulnerabilidades en dispositivos perimetrales:
Palo Alto PAN-OS (CVE-2024-3400).
Ivanti Connect Secure / Policy Secure (CVE-2023-46805, CVE-2024-21887, CVE-2024-21893).
Fortinet FortiClient EMS (CVE-2023-48788).¹⁰
2. File transfer, colaboración y CI/CD
MOVEit Transfer (CVE-2023-34362), Barracuda ESG (CVE-2023-2868), TeamCity (CVE-2023-42793), GitLab (CVE-2023-7028), Atlassian Confluence (CVE-2023-22515/22518/22527) aparecen de forma reiterada en KEV y en los listados de vulnerabilidades más explotadas por ransomware y APT.²⁷¹⁸¹⁴
3. Vulnerabilidades antiguas y log4j eterno
La CISA y resúmenes derivados señalan que las vulnerabilidades más explotadas en 2023–2024 incluyen varias CVE de 2021 o anteriores, siendo log4j (CVE-2021-44228) el caso paradigmático, vinculado a más de 31 grupos de amenazas.¹⁹³⁰¹⁸
CCN-CERT observa que entre las vulnerabilidades más explotadas en muestras de malware destacan CVE-2017-11882, CVE-2018-0802 y CVE-2017-0199 en Microsoft Office, es decir, software muy antiguo y ubicuo.¹⁴
4. CWE dominantes
ENISA y Kaspersky resaltan el peso de CWE como inyección SQL (CWE-89), inyección de comandos OS (CWE-78), path traversal (CWE-22) y upload de ficheros peligrosos (CWE-434) entre las vulnerabilidades explotadas en 2024.³²⁷
Análisis de KEV para 2024 muestran CWE-79 (XSS), CWE-20 (input validation), CWE-416 (use-after-free) y CWE-287 (improper authentication) como debilidades repetidamente asociadas a KEV.³³¹¹

- Rapid7 constata que el 24% de las vulnerabilidades explotadas en su conjunto de datos son “network pivot vulnerabilities” (puertas de pivote en el perímetro), mientras que en KEV ≈19% de las entradas afectan a dispositivos de borde o pasarelas de seguridad.¹¹⁹
- Mandiant muestra que en 2024 la mayor parte de los incidentes con exploit como vector inicial se debieron a vulnerabilidades en dispositivos perimetrales:
Palo Alto PAN-OS (CVE-2024-3400).
Ivanti Connect Secure / Policy Secure (CVE-2023-46805, CVE-2024-21887, CVE-2024-21893).
Fortinet FortiClient EMS (CVE-2023-48788).¹⁰
- Palo Alto PAN-OS (CVE-2024-3400).
- Ivanti Connect Secure / Policy Secure (CVE-2023-46805, CVE-2024-21887, CVE-2024-21893).
- Fortinet FortiClient EMS (CVE-2023-48788).¹⁰
- MOVEit Transfer (CVE-2023-34362), Barracuda ESG (CVE-2023-2868), TeamCity (CVE-2023-42793), GitLab (CVE-2023-7028), Atlassian Confluence (CVE-2023-22515/22518/22527) aparecen de forma reiterada en KEV y en los listados de vulnerabilidades más explotadas por ransomware y APT.²⁷¹⁸¹⁴
- La CISA y resúmenes derivados señalan que las vulnerabilidades más explotadas en 2023–2024 incluyen varias CVE de 2021 o anteriores, siendo log4j (CVE-2021-44228) el caso paradigmático, vinculado a más de 31 grupos de amenazas.¹⁹³⁰¹⁸
- CCN-CERT observa que entre las vulnerabilidades más explotadas en muestras de malware destacan CVE-2017-11882, CVE-2018-0802 y CVE-2017-0199 en Microsoft Office, es decir, software muy antiguo y ubicuo.¹⁴
- ENISA y Kaspersky resaltan el peso de CWE como inyección SQL (CWE-89), inyección de comandos OS (CWE-78), path traversal (CWE-22) y upload de ficheros peligrosos (CWE-434) entre las vulnerabilidades explotadas en 2024.³²⁷
- Análisis de KEV para 2024 muestran CWE-79 (XSS), CWE-20 (input validation), CWE-416 (use-after-free) y CWE-287 (improper authentication) como debilidades repetidamente asociadas a KEV.³³¹¹

4. KEV, explotación real y otros sistemas de priorización (CVSS, EPSS, NIST LEV)

4.1 CVSS vs KEV: severidad vs realidad

- CVSS mide impacto potencial, no uso real. Grandes porciones del espacio de CVEs con puntuaciones 9.x jamás se explotan de forma masiva.
- KEV, en cambio, captura únicamente vulnerabilidades con explotación confirmada y añade fecha de inclusión, acción requerida y fecha límite de remediación según BOD 22-01.33173416

En la práctica:

- KEV actúa como “capa superior” de priorización: si está en KEV, se trata como crítico aunque CVSS no sea 10/10.
- Proveedores como Qualys, Rapid7, Dynatrace, FOSSA, etc., recomiendan explícitamente priorizar KEV sobre otros criterios.³⁵³⁶³⁷³⁴³⁸⁹⁴⁵

4.2 EPSS y KEV: qué predice y qué no

Un estudio independiente en arXiv analiza la **capacidad de EPSS v3 para anticipar explotación** en CVE de alta severidad (CVSS ≥ 9.0) que posteriormente entraron en KEV.¹⁰

Resultados clave:

- Muestra: 90 CVE con CVSS ≥ 9.0 añadidas a KEV entre 15/03/2023 y 01/07/2024.²⁷
- Para CVE de 2022 o anteriores, EPSS se comporta razonablemente bien: casi todas tenían puntuaciones altas antes de su inclusión en KEV.²⁷
- Para CVE 2023+:
42 de 57 CVE ($\approx 74\%$) tenían scores bajos (dígito simple) antes de entrar en KEV.²⁷
Si se amplía a todas las 250 CVE añadidas a KEV en el periodo (sin filtrar por CVSS), más de dos tercios tenían EPSS $< 36\%$ (umbral recomendado) justo antes de su inclusión.²⁸²⁷
- 42 de 57 CVE ($\approx 74\%$) tenían scores bajos (dígito simple) antes de entrar en KEV.²⁷
- Si se amplía a todas las 250 CVE añadidas a KEV en el periodo (sin filtrar por CVSS), más de dos tercios tenían EPSS $< 36\%$ (umbral recomendado) justo antes de su inclusión.²⁸²⁷

Conclusión del autor: EPSS actúa más como **indicador rezagado** que como predictor en muchos casos, sobre todo para vulnerabilidades recientes. Una estrategia nacional o corporativa que **se limite a EPSS** dejaría abiertas muchas KEV críticas durante el periodo en que ya están siendo explotadas.¹¹¹²¹³

En cambio, combinar:

- CVSS (impacto potencial),
- KEV (explotación confirmada),
- EPSS/NIST LEV (probabilidad relativa de explotación),

ofrece un marco de **priorización multinivel** mucho más sólido.14151617

4.3 Efecto real de KEV sobre el parcheo

Bitsight ofrece la primera visión amplia (1,4 M de organizaciones) del impacto de KEV en comportamientos de parcheo:181920

- Remediación KEV 3,5 veces más rápida:
Mediana KEV: 174 días.
Mediana no-KEV: 621 días.
- Aun así, >60% de las KEV se remedia después del plazo recomendado por CISA.⁸
- Organismos federales estadounidenses, obligados por BOD 22-01, son 56% más propensos a cumplir los plazos que el resto.⁸
- KEV usadas en ransomware (≈20% del catálogo) son 64% más prevalentes que el resto, pero se remiendan 2,5 veces más rápido (el miedo es un excelente motor de SLAs).⁸
- Mediana KEV: 174 días.
- Mediana no-KEV: 621 días.

Como línea base comparativa, estos datos permiten a España plantearse objetivos del tipo: “reducir media nacional de remediación KEV críticas por debajo de 120 días” o “llevar el % de KEV fuera de plazo nacional por debajo del 40%”.

5. Dimensión europea y española

5.1 Europa: ENISA, EUVD y NIS2

El contexto europeo converge explícitamente hacia KEV:

- ENISA Threat Landscape 2024 y el briefing 2024–2025 destacan:
Phishing sigue siendo el vector inicial dominante (≈60% de incidentes).
La explotación de vulnerabilidades representa ≈21% de incidentes y ≈70% de los casos en que se usa conduce directamente a intrusión, y en ≈68% se observa despliegue de malware.⁷
42.595 vulnerabilidades divulgadas (+27%) y 245 KEV añadidas durante el periodo de análisis.⁷
- La EU Vulnerability Database (EUVD), presentada por ENISA en 2025, se alimenta de:
CSIRTs nacionales,
proveedores,
bases existentes como MITRE CVE,
y explícitamente del catálogo KEV de CISA.¹³

- Phishing sigue siendo el vector inicial dominante (≈60% de incidentes).
- La explotación de vulnerabilidades representa ≈21% de incidentes y ≈70% de los casos en que se usa conduce directamente a intrusión, y en ≈68% se observa despliegue de malware.⁷
- 42.595 vulnerabilidades divulgadas (+27%) y 245 KEV añadidas durante el periodo de análisis.⁷
- CSIRTs nacionales,
- proveedores,
- bases existentes como MITRE CVE,
- y explícitamente del catálogo KEV de CISA.¹³

Su objetivo es convertirse en **fuentes centralizadas de vulnerabilidades para la UE**, alineada con NIS2 y la futura Cyber Resilience Act.²¹

En términos de métricas nacionales, esto significa que:

- España podrá, en el medio plazo, correlacionar datos propios de exposición y remediación con EUVD, incluyendo el “flag KEV” como atributo de cada vulnerabilidad.
- Las obligaciones de NIS2 en materia de gestión de vulnerabilidades y notificación tenderán a alinear los tiempos de parcheo y el seguimiento de KEV en los Estados miembros.

5.2 España: CCN-CERT, INCIBE-CERT y patrón de explotación

CCN-CERT – Ciberamenazas y Tendencias 2024 (datos 2023)

En la sección de vulnerabilidades, CCN-CERT sintetiza tendencias muy coherentes con las observadas por CISA y ENISA:²²

- “La explotación de vulnerabilidades recientes ha sido empleada como método de acceso inicial por todo tipo de ciberamenazas, observando una predilección por el compromiso de dispositivos perimetrales vulnerables.”¹⁴
- Sin embargo, “las vulnerabilidades más explotadas siguen siendo vulnerabilidades antiguas de productos ampliamente utilizados”, destacando las CVE de Office mencionadas antes (2017–2018) con cientos o miles de observaciones.¹⁴
- Google es el proveedor que más vulnerabilidades publicó en 2023; las de Microsoft crecieron un 42% respecto a 2022.¹⁴
- En el plano geopolítico, España se sitúa entre los países más atacados por grupos hacktivistas prorrusos, principalmente mediante DDoS y campañas oportunistas asociadas al apoyo a Ucrania.¹⁵¹⁴

Aunque el informe no referencia explícitamente el catálogo KEV, muchas de las vulnerabilidades destacadas coinciden con KEV y/o con las listas de “Top Routinely Exploited Vulnerabilities” de CISA: Citrix, Fortinet, Atlassian, MOVEit, JetBrains, etc.²³²⁴²⁵

INCIBE-CERT

- La sección de alertas de vulnerabilidades incluye crecientemente referencias explícitas a KEV cuando CISA añade una CVE relevante (por ejemplo, CVE-2025-3928 en Commvault Web Server, añadida al catálogo KEV el 28/04/2025).²⁶
- INCIBE también ha difundido comunicados sobre la lista de vulnerabilidades más explotadas en 2022 reseñando avisos conjuntos de CISA y otros organismos (AA23-215A), en los que se insta a priorizar el parcheo de vulnerabilidades “rutinariamente explotadas”.²⁴¹⁹

En resumen, **España ya está operativamente alineada con KEV** a través de:

- Alertas CCN-CERT/INCIBE-CERT que siguen los advisories de CISA.
 - La adopción en curso de NIS2 y el despliegue de EUVD, que integra KEV como fuente upstream.¹⁵¹³¹⁴
-

Lo que falta, y aquí está la oportunidad, es **traducir esa alineación operativa en métricas agregadas de país**.

6. Propuesta de marco de indicadores KEV a nivel nacional (España)

A efectos de política pública, supervisión sectorial y benchmarking internacional, puede articularse un sistema de indicadores KEV en tres niveles:

5. Exposición: ¿cuántas y qué tipo de KEV afectan a activos en España?
6. Capacidad de respuesta: ¿con qué rapidez y consistencia se remedia?
7. Resultados e impacto: ¿hasta qué punto KEV se traduce en incidentes reales?

6.1 Indicadores de exposición

E1. Porcentaje de organizaciones españolas con ≥ 1 KEV expuesta

- Definición:
 - Nº de organizaciones en España con al menos una vulnerabilidad incluida en KEV detectada en activos expuestos a Internet / Nº total de organizaciones analizadas.
- Línea base global: 35% (muestra Bitsight, 1.4 M entidades).⁸
- Posible desagregación: por comunidad autónoma, por tamaño (PYME, gran empresa), por sector (ENS, operadores esenciales NIS2, etc.).
- Fuentes:
 - Telemetría de proveedores de rating/scan (Bitsight, SecurityScorecard, Shodan-like).
 - Datos agregados anonimizados de SOC gubernamentales y operadores críticos.
- Telemetría de proveedores de rating/scan (Bitsight, SecurityScorecard, Shodan-like).
- Datos agregados anonimizados de SOC gubernamentales y operadores críticos.

E2. Densidad media de KEV por organización expuesta

- Definición:
 - Nº total de KEV detectadas en organizaciones españolas / Nº de organizaciones con al menos una KEV.
- Bitsight reporta que, entre quienes tienen KEV, el 66% tiene >1 , el 25% ≥ 5 , y el 10% ≥ 10.8
- Permite fijar metas del tipo: “Reducir el porcentaje de organizaciones con ≥ 5 KEV abiertas por debajo del 15%”.

E3. Distribución tipo de KEV por tecnología en España

- Categorías sugeridas:
Dispositivos perimetrales (VPN, firewalls, WAF, load balancers).
File transfer / almacenamiento.
Plataformas de colaboración (Exchange, Confluence, etc.).
Infraestructura CI/CD y DevOps (TeamCity, GitLab...).911102714
- Objetivo: identificar “puntos calientes nacionales” (por ejemplo, sobreexposición a un fabricante perimetral concreto en determinados sectores).
- Dispositivos perimetrales (VPN, firewalls, WAF, load balancers).
- File transfer / almacenamiento.
- Plataformas de colaboración (Exchange, Confluence, etc.).
- Infraestructura CI/CD y DevOps (TeamCity, GitLab...).911102714

6.2 Indicadores de capacidad de respuesta

R1. Tiempo medio/mediano de remediación de KEV en España

- Definición:
 - Mediana de días desde la fecha de inclusión en KEV hasta la fecha de cierre efectivo (parche o mitigación) para cada vulnerabilidad observada en organizaciones españolas.
- Línea base global:
Mediana KEV global: 174 días.
Mediana KEV críticas: 137 días.8
- Posible objetivo español:
“Reducir mediana KEV críticas a <120 días y KEV de cualquier severidad a <150 días en 3 años.”
- Mediana KEV global: 174 días.
- Mediana KEV críticas: 137 días.8
- “Reducir mediana KEV críticas a <120 días y KEV de cualquier severidad a <150 días en 3 años.”

R2. Porcentaje de KEV remediadas dentro del plazo recomendado por CISA

- CISA fija plazos por defecto:
CVE con ID anterior a 2021: ≤ 6 meses.
Resto: ≤ 2 semanas (aunque posteriormente ha habido ajustes).17428
- Bitsight: $>60\%$ de KEV se remedia fuera de plazo a nivel global, pero las agencias federales cumplen plazos en un % significativamente superior.8
- Indicador español:
Nº de KEV observadas en organizaciones españolas remediadas antes de la fecha límite KEV /
Total de KEV observadas.
Desglosable por sector crítico, administración pública, etc.
- CVE con ID anterior a 2021: ≤ 6 meses.
- Resto: ≤ 2 semanas (aunque posteriormente ha habido ajustes).17428
- Nº de KEV observadas en organizaciones españolas remediadas antes de la fecha límite KEV /
Total de KEV observadas.
- Desglosable por sector crítico, administración pública, etc.

R3. Porcentaje de activos perimetrales críticos con KEV abiertas

- Dado que la mayoría de campañas recientes explotan dispositivos de borde, conviene disponer de un indicador específico:1191014
Nº de dispositivos perimetrales expuestos con alguna KEV abierta / Nº total de dispositivos perimetrales expuestos inventariados.
Posible objetivo: “Ningún organismo sujeto al ENS con dispositivos perimetrales en producción con KEV abiertas más allá del plazo KEV”.
- Nº de dispositivos perimetrales expuestos con alguna KEV abierta / Nº total de dispositivos perimetrales expuestos inventariados.
- Posible objetivo: “Ningún organismo sujeto al ENS con dispositivos perimetrales en producción con KEV abiertas más allá del plazo KEV”.

6.3 Indicadores de impacto

I1. Porcentaje de incidentes significativos vinculados a KEV

- **Definición:**
 - Nº de incidentes de gravedad alta o muy alta (según taxonomía nacional) en los que el vector inicial o de escalada explotó una CVE incluida en KEV / Nº total de incidentes de esa gravedad en el periodo.
- **Fuentes:**
CCN-CERT, INCIBE-CERT, CSIRTs sectoriales.
- **Alineación con CISA/ENISA:**
CISA y los advisories “Top Routinely Exploited Vulnerabilities” ya etiquetan incidentes por CVE y CWE.1918
ENISA también clasifica incidentes por vector (phishing, exploit, etc.).7
- CCN-CERT, INCIBE-CERT, CSIRTs sectoriales.
- CISA y los advisories “Top Routinely Exploited Vulnerabilities” ya etiquetan incidentes por CVE y CWE.1918
- ENISA también clasifica incidentes por vector (phishing, exploit, etc.).7

I2. Incidentes KEV por millón de habitantes / por 1.000 organizaciones

- Permite comparaciones internacionales (a partir de datos compartidos o informes de ENISA) y entre regiones españolas.
- Útil para priorizar inversión pública en concienciación, apoyo a PYMEs, etc.

I3. Incidentes KEV en infraestructuras críticas

- Subconjunto de I1/I2 focalizado en sectores contemplados por NIS2, Ley PIC, etc.:
Energía, transporte, sanidad, agua, financiero, digital, etc.
- La combinación “KEV + sector crítico” debería desencadenar umbral de atención regulatoria y requisitos de reporte reforzados.
- Energía, transporte, sanidad, agua, financiero, digital, etc.

7. Recomendaciones estratégicas para España (nivel país)

8. Integrar explícitamente KEV en el Esquema Nacional de Seguridad (ENS) y la transposición de NIS2
Incluir referencias a KEV en las medidas de gestión de vulnerabilidades, con obligación explícita de:
Monitorizar el catálogo KEV.
Definir SLAs diferenciados para KEV vs otras vulnerabilidades.
Reportar métricas agregadas de remediación KEV a CCN-CERT/autoridades competentes.

9. Construir un “panel KEV nacional”
Integrar fuentes:
Telemetría de proveedores comerciales (Bitsight, SecurityScorecard, etc.).
Información agregada de CCN-CERT/INCIBE-CERT.
Datos de EUVD y del programa CVE de ENISA.13157148

Objetivo: tener indicadores E/R/I (exposición, respuesta, impacto) por sector y territorio.

10. Aprovechar KEV como “mínimo común denominador” regulatorio
Para operadores de servicios esenciales y entidades importantes NIS2, establecer como obligación de resultado (no solo de medios) que:
No existan KEV críticas abiertas más allá de X días.
Se mantenga un % máximo de KEV abiertas por activo perimetral.

11. Convergencia con marcos internacionales
Alinear las métricas KEV nacionales con:
NIST CSF 2.0 (funciones Identify, Protect, Detect, Respond, Recover).³⁹
Prácticas de priorización combinando CVSS, KEV, EPSS/NIST LEV, ya adoptadas por grandes proveedores.²⁰⁴²⁸⁹³⁹²⁷

12. Promover transparencia sectorial

Publicar de forma anonimizada, por sectores, indicadores anuales de:

Media de KEV por organización.

Mediana de tiempo de remediación de KEV críticas.

Porcentaje de incidentes significativos vinculados a KEV.

- Incluir referencias a KEV en las medidas de gestión de vulnerabilidades, con obligación explícita de:
 - Monitorizar el catálogo KEV.
 - Definir SLAs diferenciados para KEV vs otras vulnerabilidades.
 - Reportar métricas agregadas de remediación KEV a CCN-CERT/autoridades competentes.
- Monitorizar el catálogo KEV.
- Definir SLAs diferenciados para KEV vs otras vulnerabilidades.
- Reportar métricas agregadas de remediación KEV a CCN-CERT/autoridades competentes.
- Integrar fuentes:
 - Telemetría de proveedores comerciales (Bitsight, SecurityScorecard, etc.).
 - Información agregada de CCN-CERT/INCIBE-CERT.
 - Datos de EUVD y del programa CVE de ENISA.13157148
- Objetivo: tener indicadores E/R/I (exposición, respuesta, impacto) por sector y territorio.
- Telemetría de proveedores comerciales (Bitsight, SecurityScorecard, etc.).
- Información agregada de CCN-CERT/INCIBE-CERT.
- Datos de EUVD y del programa CVE de ENISA.13157148
- Para operadores de servicios esenciales y entidades importantes NIS2, establecer como obligación de resultado (no solo de medios) que:
 - No existan KEV críticas abiertas más allá de X días.
 - Se mantenga un % máximo de KEV abiertas por activo perimetral.
- No existan KEV críticas abiertas más allá de X días.
- Se mantenga un % máximo de KEV abiertas por activo perimetral.

- Alinear las métricas KEV nacionales con:
NIST CSF 2.0 (funciones Identify, Protect, Detect, Respond, Recover).39
Prácticas de priorización combinando CVSS, KEV, EPSS/NIST LEV, ya adoptadas por grandes proveedores.2042893927
- NIST CSF 2.0 (funciones Identify, Protect, Detect, Respond, Recover).39
- Prácticas de priorización combinando CVSS, KEV, EPSS/NIST LEV, ya adoptadas por grandes proveedores.2042893927
- Publicar de forma anonimizada, por sectores, indicadores anuales de:
Media de KEV por organización.
Mediana de tiempo de remediación de KEV críticas.
Porcentaje de incidentes significativos vinculados a KEV.
- Media de KEV por organización.
- Mediana de tiempo de remediación de KEV críticas.
- Porcentaje de incidentes significativos vinculados a KEV.

Así, España podría situarse como **referente europeo en “KEV-driven cyber metrics”**, algo muy alineado con el papel creciente de ENISA como CNA (CVE Numbering Authority) y con la EUVD.262728

8. Módulo de encuesta: preguntas y opciones de respuesta (tono ameno, irónico y útil)

A continuación se proponen bloques de preguntas tipo para encuestas dirigidas a organizaciones españolas (CISOs, responsables de TI, etc.), orientadas a captar **madurez en el uso de KEV**. Cada una incluye un conjunto de **respuestas tipo**, formuladas en un tono profesional pero con un punto irónico que ayuda a que la gente responda con menos dolor de corazón.

8.1 Gobernanza y política de vulnerabilidades

P1. En su organización, ¿cómo se integra el catálogo KEV de CISA en la política de gestión de vulnerabilidades?

Opciones sugeridas:

- a) “KEV está explícitamente mencionado en nuestra política y define SLAs diferenciados de parcheo.”
- b) “Usamos KEV como una de varias fuentes (junto con CVSS, EPSS, etc.), pero sin SLAs formales específicos.”
- c) “Lo revisamos cuando hay una gran noticia o un advisory grave, pero no de forma sistemática.”
- d) “Conocemos KEV de oídas; por ahora vivimos felices en el universo CVSS y ‘ya si eso’.”

P2. ¿Quién es el responsable último de que las KEV críticas se remedien en plazo?

Opciones:

- a) “Responsable de ciberseguridad con mandato explícito y apoyo de dirección.”
- b) “Compartido entre TI, ciberseguridad y los dueños de negocio (modelo colegiado).”
- c) “En teoría TI; en la práctica, cada proyecto se apaña como puede.”
- d) “Nadie en concreto: confiamos en la energía cósmica del parche mensual.”

8.2 Procesos y métricas internas

P3. ¿Con qué frecuencia se revisan las nuevas entradas de KEV frente a su inventario de activos?

- a) “Diariamente (integrado en herramientas y/o procesos SOC).”
- b) “Semanalmente.”
- c) “Mensualmente, salvo emergencias mediáticas.”
- d) “Solo cuando nos llega un boletín alarmante... o nos llama el proveedor.”

P4. ¿Qué indicadores relacionados con KEV monitoriza regularmente su organización? (selección múltiple posible)

Opciones de respuesta (tipo lista de chequeo):

- “Número de KEV abiertas por activo / por entorno (producción, preproducción...).”
- “Tiempo medio de remediación de KEV críticas y altas.”
- “Porcentaje de KEV remediadas dentro del plazo CISA o interno equivalente.”
- “Porcentaje de incidentes significativos en los que intervino alguna KEV.”
- “Ninguno todavía; medimos sobre todo el número de parches instalados y la longitud de la hoja Excel.”

8.3 Tecnología y herramientas

P5. ¿Cómo consumen técnicamente la información de KEV?

- a) “Integración automática (API/feeds) en soluciones de gestión de vulnerabilidades o GRC.”
- b) “A través de herramientas comerciales que ya incorporan la etiqueta KEV (scanners, ASM, etc.).”
- c) “Descarga manual/periódica del catálogo KEV para cruces puntuales.”
- d) “Principalmente vía artículos de prensa, blogs técnicos o boletines de terceros.”

P6. De las vulnerabilidades detectadas en sus activos, ¿cómo prioriza actualmente?

- a) “Primero KEV, luego EPSS/LEV, luego CVSS y contexto de negocio.”
- b) “Primero CVSS (críticas), y dentro de ellas damos prioridad a KEV cuando las hay.”
- c) “Priorizamos por impacto en negocio percibido y la ventana de mantenimiento disponible; KEV es un factor más.”
- d) “Lo prioriza el calendario: lo que cae en el parche mensual entra; lo demás espera tiempos mejores.”

8.4 Cultura y percepción de riesgo

P7. ¿Cómo describiría la actitud de su organización hacia las KEV?

- a) “Son tratadas como emergencias gestionadas: pocas, muy serias y con foco de dirección.”
- b) “Se consideran importantes, pero compiten en igualdad con otras tareas técnicas.”
- c) “Generan cierta fatiga: ‘otra lista más’ que añadir a las mil ya existentes.”
- d) “KEV es esa cosa de la que habla el proveedor antes de enseñarnos el PowerPoint de ventas.”

P8. En términos de comunicación interna, cuando se notifica una KEV crítica, ¿qué ocurre?

- a) “Se activa un procedimiento claro: evaluación de impacto, ventana de parcheo, seguimiento hasta cierre.”
- b) “Se abre un ticket prioritario y se intenta encajar en el próximo ciclo de cambios.”
- c) “Se reenvía un correo masivo con asunto en mayúsculas y se confía en la buena voluntad del destinatario.”
- d) “Se guarda en la carpeta de ‘asuntos serios’ para la próxima reunión en la que haya tiempo (spoiler: nunca).”

9. Cierre

El catálogo KEV de CISA ha pasado, en pocos años, de ser una iniciativa “doméstica” para agencias federales estadounidenses a un **estándar de facto mundial de priorización de vulnerabilidades explotadas**. ENISA lo integra en la base de datos europea EUVD; grandes proveedores de seguridad lo incorporan como señal de riesgo de primera clase; los estudios empíricos muestran que **las KEV**

se corrigen más rápido que el resto, aunque todavía demasiado despacio para el gusto de cualquier ransomware mínimamente ambicioso.293031323334

Para España, el camino lógico –y estratégico– pasa por:

- Adoptar KEV como eje vertebrador de métricas nacionales de ciberseguridad, especialmente en sectores críticos y Administración.
- Medirse sistemáticamente frente a líneas base globales (porcentaje de organizaciones con KEV, tiempos de remediación, peso de KEV en incidentes graves).
- Aprovechar la sinergia con NIS2, ENS y EUVD para construir un panel de indicadores que permita a reguladores, CSIRTs y organizaciones hablar el mismo idioma cuando discuten de riesgo: no de CVEs en abstracto, sino de las vulnerabilidades que ya se están usando contra nosotros.15137148

Y, por supuesto, hacerlo sin perder el sentido del humor: porque si algo enseñan los datos de KEV es que **parchar tarde es una tradición muy humana**, pero también que, cuando se dan señales claras y medibles, los comportamientos cambian. El reto ahora es que esas señales y métricas se definan **a nivel país**, y ahí es donde España puede jugar muy bien sus cartas.

4344454647484950515253545556575859606162636465666768697071727374757677787980
81828384
